

Threat Model & Security Architecture

The STRIDE threat model developed for this project outlines potential security threats across the major components of the Mental Health & Inclusion Hub Platform. Each module, such as the login system, file upload handler, chatbot, admin panel, mood prediction model, and logging service was analysed under the STRIDE categories. For every threat identified, realistic examples were provided alongside corresponding mitigations. These included applying standard security practices such as password hashing, HTTPS encryption, role-based access control, input sensitisation, and rate limiting. The purpose of this model is to demonstrate how different features of the system might be exploited and to provide clear defensive strategies that reduce the likelihood or impact of such threats.

Module	STRIDE Category	Threat Example	Impact	Mitigation Strategy
Login System	Spoofing	Attacker impersonates a valid user using stolen credentials	Unauthorised access to platform and data	Use secure login, session tokens, password hashing (e.g. bcrypt)
	Information Disclosure	Login credentials intercepted during submission	Credential leakage	Use HTTPS for encrypted transmission
File Upload System	Tampering	User uploads a file with embedded malware	Malicious content execution or storage	Validate file type/extensions, sanitise filenames, scan and monitor uploads
	Information Disclosure	Uploaded files are accessible without proper authorisation	Leakage of user content	Secure file storage with access control
	Denial of Service	Uploads of large or malicious files to overload server	System slowdown or crash	File size limits, upload rate limits
Chatbot Input	Elevation of Privilege	User injects code via chat to gain access to backend	Backend compromise	Sanitise input, filter dangerous characters, rate-limit commands
	Tampering	User sends malformed or toxic input to disrupt logic	Chatbot crashes or provides incorrect responses	Input validation and error handling
	Denial of Service	Flood chatbot with messages	Chatbot unresponsive or slow	Rate-limiting per user, spam flag after 5 messages
Admin Panel	Spoofing	Non-admin tries to access logs export feature	Unauthorised access to audit logs	Role-based access control, admin-only features
	Information Disclosure	Admin panel leaks logs with sensitive info (e.g. passwords, IPs)	Privacy risk, user data exposure	Mask passwords, protect export endpoints, use admin authentication
Logging System	Repudiation	User denies having logged in or taking action on the system	Inability to audit or investigate incidents, lack of accountability	Log all actions and logins with user ID, IP, username, timestamp, event type

Module	STRIDE Category	Threat Example	Impact	Mitigation Strategy
	Information Disclosure	Logs are accessible publicly or stored insecurely	Sensitive information leakage	Secure storage, restrict read access, encrypt logs if needed
Mood Prediction Model	Information Disclosure	Health data inputs (e.g. sleep, activity, age) exposed	Breach of personal/sensitive user data	De-identify stored inputs, transmit via HTTPS
	Tampering	Malicious user alters inputs to test vulnerabilities	Model outputs invalid predictions	Sanitise and validate user inputs before model processing

To complement the STRIDE analysis, a visual system architecture diagram was created to map how data flows through the platform and where trust boundaries exist. On the right-hand side of the diagram, user input sources are positioned as un-trusted entry points. These are separated from the core application logic by a clearly marked trust boundary. Within that boundary are secure modules that process, store, and respond to user data. Between the un-trusted inputs and these core modules, mitigation strategies are applied. All modules connect to a central database that stores logs, mood data, user accounts, and uploaded content under strict access control. This diagram illustrates how the architecture supports confidentiality, integrity, and availability by enforcing separation between external data and trusted services, ensuring all inputs are validated or authenticated before entering the trusted zone. It also visually ties the STRIDE threats and their mitigations to their relevant flow paths and control points, making the security model of the system easier to explain and justify.

